

August 29, 2025

Android Malware Campaign Targets Indian Banking Users

CERTMH_CTI_2025_37

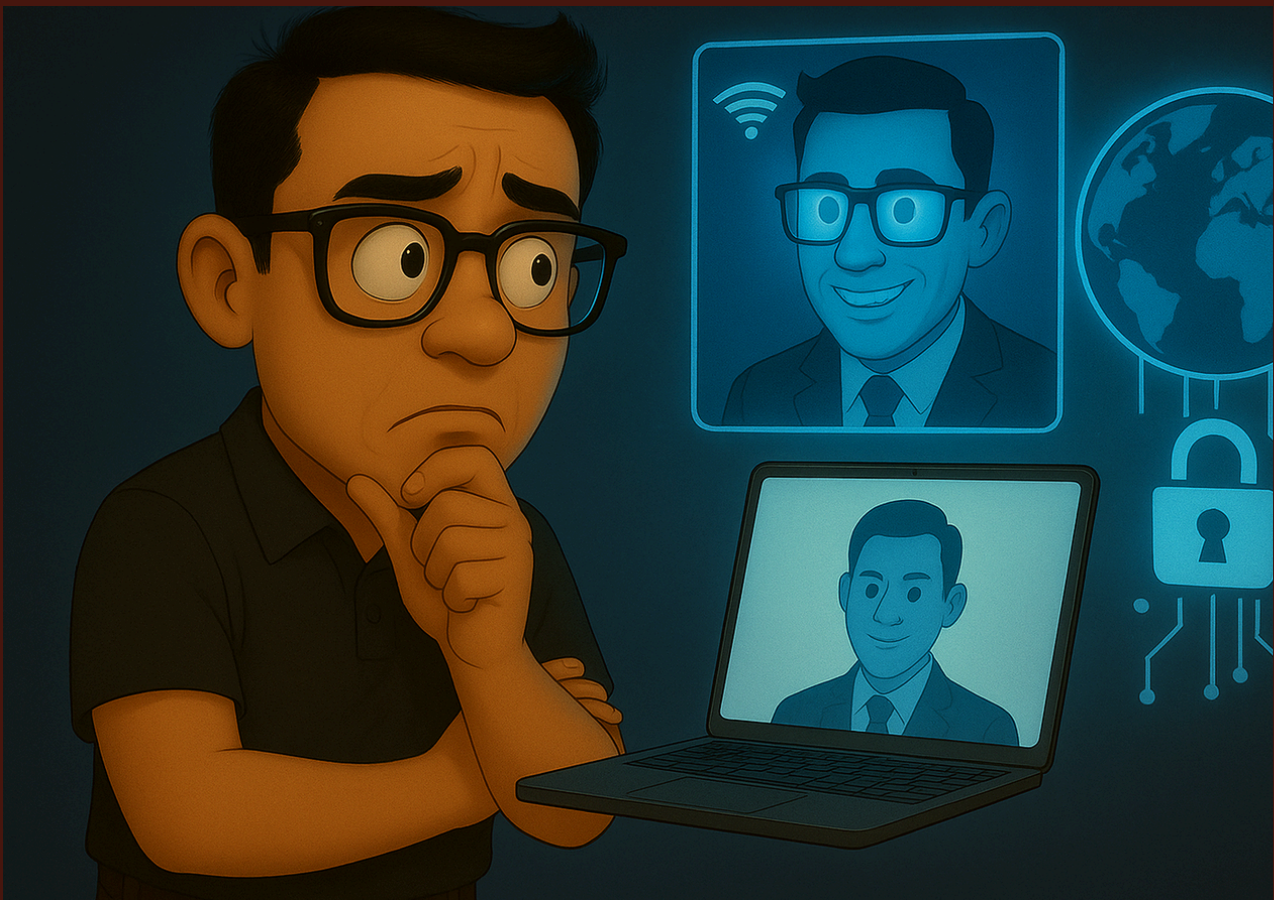


Table of Contents

INTRODUCTION	1
THREAT DETAILS	5
TECHNICAL FINDINGS	6
MALWARE THREAT ANALYSIS	9
RECOMMENDATIONS	10
INDICATOR OF COMPROMISE	11
REFERENCES	12

EXECUTIVE SUMMARY

Analysis of Android Malware Campaign



This report identifies a significant **Android malware campaign** aimed at Hindi-speaking users in India. This campaign impersonates legitimate financial applications and utilizes phishing websites to harvest sensitive user data.

Security Researcher findings reveal sophisticated evasion techniques that allow the malware to remain undetected by conventional security measures. The implications for the BFSI sector are profound, highlighting the urgent need for enhanced security protocols and user awareness initiatives. Stakeholders must act promptly to mitigate risks and safeguard customer information against these evolving threats.

A sophisticated Android malware campaign specifically targeting Hindi-speaking users in India through fraudulent banking applications. The malware mimics trusted financial institutions, including SBI Card, Axis Bank, and IndusInd Bank, utilizing convincing phishing websites that incorporate legitimate assets from official banking sites to deceive victims into downloading malicious applications.

This threat demonstrates advanced evasion techniques through a multi-stage payload delivery system and incorporates dual malicious functionality, combining traditional financial data theft with covert cryptocurrency mining operations. The campaign leverages Firebase Cloud Messaging (FCM) to remotely trigger Monero mining activities on infected devices, representing a significant evolution in mobile malware capabilities that poses substantial risks to both individual users and organizational security frameworks.

This threat demonstrates advanced evasion techniques through a multi-stage payload delivery system and incorporates dual malicious functionality, combining traditional financial data theft with covert cryptocurrency mining operations. The campaign leverages Firebase Cloud Messaging (FCM) to remotely trigger Monero mining activities on infected devices, representing a significant evolution in mobile malware capabilities that poses substantial risks to both individual users and organizational security frameworks.



Above figure represent Geographic distribution of infected devices

THREAT DETAILS

Region Affected: Primarily targets India with localized lures; limited detections globally.

Industries Affected: Financial services, mobile banking users

Delivery & Infection Mechanism

Phishing Sites:

1. Clone official Indian bank sites (e.g., [www.sbi.mycardcare\[.\]in](http://www.sbi.mycardcare[.]in), [kotak.mycardcard\[.\]in](http://kotak.mycardcard[.]in))
2. Deliver fake Android APKs disguised as legitimate app updates

Dropper Technique:

1. Malware APKs initially appear benign
2. On execution, they decrypt and load a secondary malicious payload

Stages:

1. Encrypted DEX loader file is decrypted using XOR key
2. Loader fetches and decrypts a second-stage payload
3. Final payload mimics banking interface to phish credentials

Credential Theft Operation

- Fake UI mimics real banking apps
- Prompts victims for: Cardholder name, Credit card number, CVV, Expiry date
- Stolen data exfiltrated to C2 servers

Cryptocurrency Mining Functionality

- Uses XMRig (an open-source Monero miner)
- Triggered via Firebase Cloud Messaging (FCM) commands
- Executes hidden background mining on mobile devices using:
- Downloaded .so binary (native library)
- Java ProcessBuilder to simulate legitimate mining CLI
- Hardcoded URLs used to download encrypted mining binaries

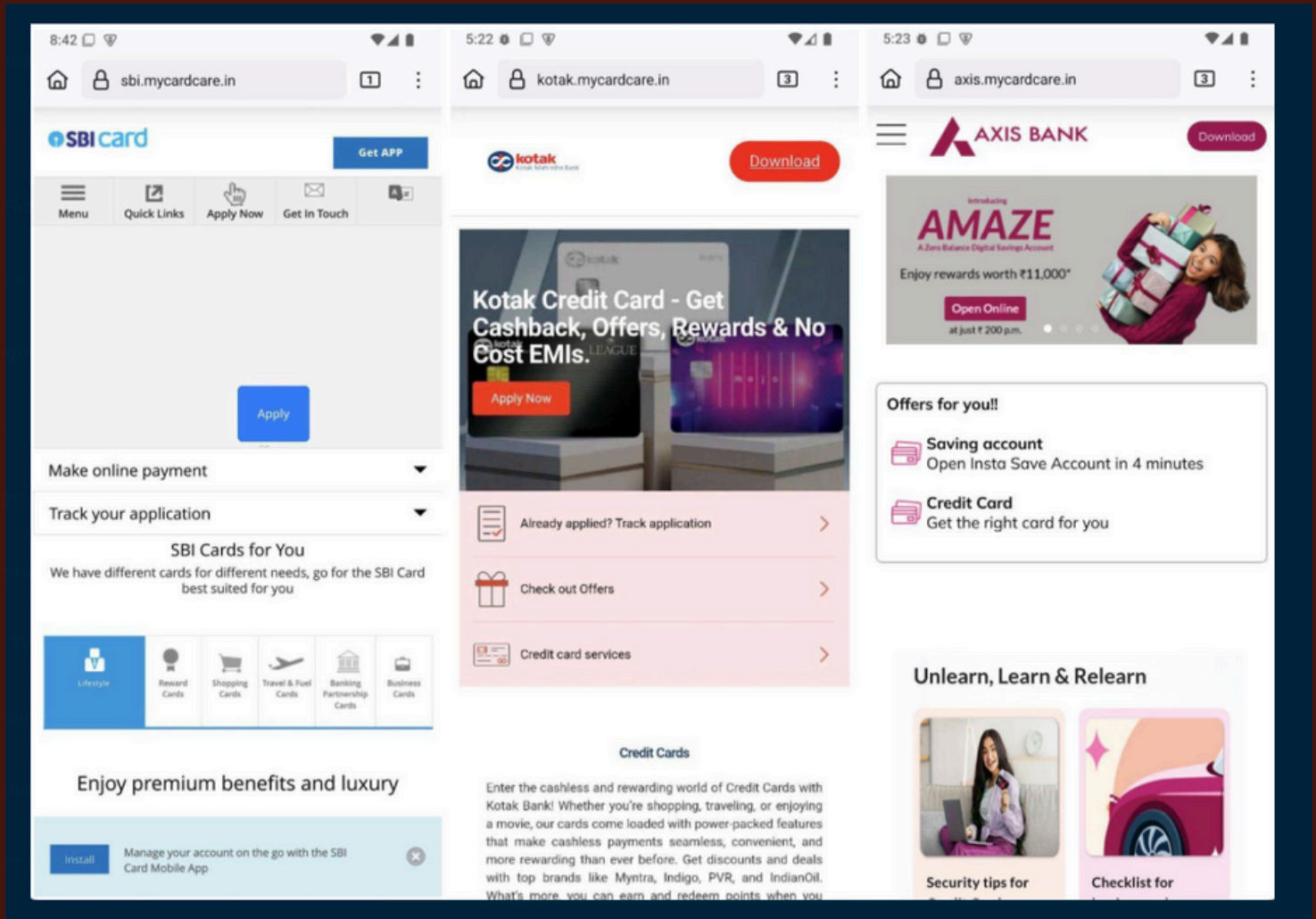
Stealth & Evasion

- Multi-stage payload loading to evade static analysis
- Use of Firebase for remote activation and C2 commands
- Combines social engineering (banking disguise) with technical obfuscation

Technical Findings

Distribution Methods

The malware is distributed through phishing websites that impersonate Indian financial services. These sites are designed to closely resemble official banking sites and trick users into downloading a fake Android app. Here are some phishing sites we found during our investigation.



Above Figure represent Screenshot of a phishing website

Dual-Threat Campaign

This malware is distinguished by its dual functionality: it not only steals sensitive personal and financial information but also secretly mines Monero cryptocurrency using the open-source XMRig tool, remotely triggered via Firebase Cloud Messaging (FCM).

Disguised as a Google Play update, it exploits user trust to drive installations that result in data exfiltration.

As part of the App Defense Alliance, Researchers reported the threat to Google, leading to the suspension of the associated FCM account to prevent further spread.

McAfee Mobile Security categorizes all identified variants as high-risk, with telemetry showing the majority of infections in India and a few instances detected globally.

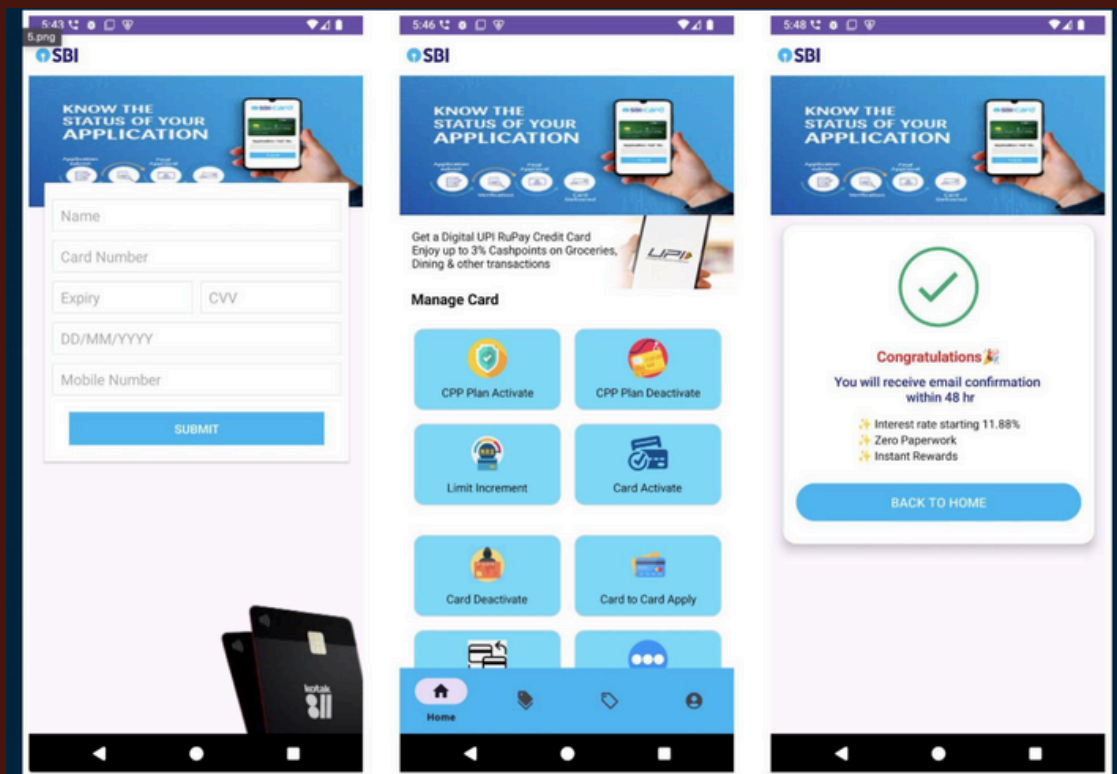
Cryptomining Payload

The malware leverages a multi-stage dropper architecture to evade static analysis and detection.

Following installation, the APK displays a fake Google Play interface prompting users to perform an “update.” In the background, it decrypts an embedded DEX file from the assets folder using an XOR key.

This first-stage loader subsequently decrypts and dynamically executes a second-stage payload, which impersonates a legitimate financial application interface.

Victims are then deceived into entering sensitive information such as full names, card numbers, CVVs, and expiration dates, which are exfiltrated to a command-and-control (C2) server.



Above figure represent Fake card verification screen

After users submit their information, the app displays a fake confirmation page, simulating legitimacy with messages about pending email verification within 48 hours, though no real functionality exists.

Within the second-stage code, a Firebase messaging service is declared in the manifest to receive remote commands. These commands initiate the mining module by downloading an encrypted .so binary from one of three hardcoded URLs. The binary is executed through Java's ProcessBuilder as a standalone process, using arguments that replicate XMRig's command-line options, including Monero mining pool configurations.

The malware leverages the RandomX algorithm, which is optimized for CPU mining, making it effective even on mobile devices. Monero's privacy-focused design conceals transactions, enabling attackers to launder mined cryptocurrency undetected. Logs from the decrypted binary confirm XMRig's integration, allowing silent cryptojacking operations without user awareness.

This campaign extends earlier threats observed in India, as reported by McAfee, but introduces key innovations—combining real-time phishing, staged payload decryption, and remote activation via Firebase Cloud Messaging (FCM). The multi-stage dropper design complicates reverse engineering, while FCM-based triggers keep the malware dormant until activated, minimizing detection risk.

Distribution relies on phishing sites containing “Get App” buttons, commonly shared through SMS, WhatsApp, and social media.

RISK ASSESSMENT

Understanding Risks for Banking Users

Credential Theft & Financial Fraud

- Fake banking UIs harvest sensitive details (Cardholder Name, Number, CVV, Expiry).
- High probability of direct financial loss for customers.
- Risk of large-scale fraud targeting BFSI institutions.



Cryptocurrency Mining (Cryptojacking)

- Covert Monero mining drains device performance and battery life.
- Increases operational costs for enterprises (bandwidth, energy).
- Potential to go undetected for long periods due to remote activation via FCM.



User Trust & Reputation Risk

- Fake banking apps impersonating legitimate bank names
- Loss of consumer confidence in digital banking apps.
- Negative regulatory / compliance scrutiny.



RECOMMENDATIONS

◆ For End-Users

- Download apps only from trusted sources such as Google Play; avoid APKs from third-party or unknown websites.
- Do not click on unsolicited links received via SMS, WhatsApp, email, or social media, especially those promoting financial apps or updates.
- Be cautious when entering personal or banking information—verify the legitimacy of apps before sharing sensitive data.
- Use a reliable mobile security solution that can detect malicious applications, block phishing attempts, and monitor suspicious behavior.
- Stay alert to unusual update prompts outside of official app stores, which may indicate malware attempts.

◆ For Enterprises

Note: MH-CERT recommends implementing the above strategic security controls to mitigate risks from that are arising out of the these highly active APT groups that are targeting globally. It is strongly advised that organizations perform thorough business impact analysis, carefully evaluate each control in the context of their operational environment and business continuity requirements before applying above recommendations.

- Enforce Mobile Device Management (MDM) policies to restrict installation of applications from unverified sources.
- Implement app whitelisting to allow only approved apps on corporate devices.
- Monitor network traffic for anomalies such as connections to suspicious domains, hardcoded URLs, or Monero mining pools.
- Block Indicators of Compromise (IOCs)—such as malicious IPs, domains, and file hashes across security tools.
- Detect and block command-and-control (C2) communications, including those leveraging Firebase Cloud Messaging (FCM).
- Conduct regular user awareness training to educate employees on risks from phishing links, fake updates, and malicious mobile apps.

INDICATOR OF COMPROMISE

A comprehensive list of Indicator of Compromise (IoC's) can be found in [Mahacyber Github repository](#).

Value	Description
2c1025c92925fec9c500e4bf7b4e9580f9342d44e21a34a44c1bce435353216c	SBI Credit Card
b01185e1fba96209c01f00728f6265414dfca58c92a66c3b4065a344f72768ce	ICICI Credit Card
80c6435f859468e660a92fc44a2cd80c059c05801dae38b2478c5874429f12a0	Axis Credit Card
59c6a0431d25be7e952fcfb8bd00d3815d8b5341c4b4de54d8288149090dcd74	IndusInd Credit Card
40bae6f2f736fcf03efdbe6243ff28c524dba602492b0dbb5fd280910a87282d	Kotak Credit Card
https[:]//www.sbi.mycardcare[.]in	Phishing Site
https[:]//kotak.mycardcard[.]in	Phishing Site
https[:]//axis.mycardcare[.]in	Phishing Site
https[:]//indusind.mycardcare[.]in	Phishing Site
https[:]//icici.mycardcare[.]in	Phishing Site

REFERENCES

- <https://gbhackers.com/new-android-malware-poses-as-sbi-card-and-axis-bank-apps/>
- <https://www.mcafee.com/blogs/other-blogs/mcafee-labs/android-malware-targets-indian-banking-users-to-steal-financial-info-and-mine-crypto/>